

SECCIÓN 3.6



Comunicación interna y señales de movimiento lateral

Temas de esta sección:

- Por qué el tráfico interno también importa en SOC
- Qué es movimiento lateral y por qué no siempre se ve como malware
- Protocolos internos: SMB, RDP, WinRM, LDAP, Kerberos
- Reconocimiento interno: comandos, queries, enumeración
- Diferencia entre actividad de IT legítima y movimiento lateral
- Cuentas administrativas y shares administrativos
- Señales que aumentan la sospecha



El movimiento lateral es el conjunto de acciones que realiza un atacante para desplazarse desde un sistema comprometido hacia otros dentro de la red. Ocurre después del acceso inicial y suele usar herramientas y protocolos legítimos.

El objetivo puede ser:

- ▶ Acceder a información sensible
- ▶ Buscar credenciales
- ▶ Llegar a servidores críticos
- ▶ Acceder a controladores de dominio
- ▶ Preparar exfiltración
- ▶ Desplegar malware o ransomware

Por eso se usa:

- ▶ Login remoto exitoso (RDP, SSH)
- ▶ Acceso SMB a carpetas
- ▶ WinRM / WMI para ejecución
- ▶ PsExec / copia de archivos
- ▶ Uso de cuentas privilegiadas
- ▶ Creación de servicios remotos

Las mismas técnicas pueden ser usadas por IT o por un atacante. La diferencia está en el contexto.



El mismo patrón puede ser legítimo o sospechoso según el contexto:

ACTIVIDAD LEGÍTIMA DE IT

User: soporte.admin
Source Host: IT-ADM-02
Tool: software_deploy.exe
Destinations: 120 workstations
Protocol: SMB / WinRM
Time: 22:00
Change Ticket: CHG-2026-2201

- Ticket de cambio aprobado
- Host administrativo de origen
- Herramienta corporativa
- Usuario de IT
- Ventana de mantenimiento
- Despliegue habitual

ACTIVIDAD SOSPECHOSA

User: rrhh.silva
Source Host: HR-LAP-044
Process: psexec.exe
Destinations: 18 servers
Protocol: SMB
Time: 01:30 AM
Ticket: None
File copied: update.exe

- Sin ticket de cambio
- Usuario no técnico
- Herramienta de ejecución remota
- Múltiples servidores
- Horario inusual
- Copia y ejecución de archivo

3.6 | Señales que aumentan la sospecha de movimiento lateral



Cuando más señales se combinan, más fuerte es la hipótesis de movimiento lateral:

Comunicación interna desde host no habitual	Uso de cuentas privilegiadas sin ticket	Acceso a múltiples hosts en poco tiempo
SMB, RDP, WinRM o WMI fuera de patrón	Logins fallidos y exitosos combinados	Uso de shares administrativos (C\$, ADMIN\$)
Copia de ejecutables a hosts remotos	Creación de servicios remotos	Actividad fuera de horario
Secuencia posterior a phishing o malware	Acceso a servidores críticos sin justificación	Falta de ticket o cambio aprobado

Una señal puede ser ambigua. Varias señales combinadas → hipótesis sólida → escalar con evidencia.